أهمية الـ SIEM في مركز العمليات الأمنية (SOC)

الـ **SIEM (Security Information and Event Management)** هو العصب الرئيسي لكل محلل أمني. يجمع البيانات، يربط الأحداث، ويمنح الفريق رؤية شاملة وفورية لكل ما يجري في البنية التحتية — من نقطة واحدة موحّدة.

القدرات الجوهرية للـ SIEM

يرتكز الـ SIEM على أربع ركائز تجعله أداة لا غنى عنها في بيئة الـ SOC الاحترافية.

Correlation — الربط

يربط الأحداث المتفرقة مع بعضها ليُتيح تحليلاً كاملاً وشاملاً للهجوم من بدايته حتى نهايته.

Centralisation — المركزية

يجمع كل البيانات من مصادر متعددة في مكان واحد، مما يُسهّل التحقيق ومقارنة الأحداث عبر الأنظمة.

Dashboards & Automation

يدعم قواعد الكشف (Detection Rules)، التنبيهات الآلية، والتصور البياني الفوري للتهديدات.

Historical Events — الأحداث السابقة

يُمكّن المحللين من الرجوع للأحداث القديمة لتحديد الأنماط والتهديدات المتكررة وتتبع الجذور.

⚠️ Emily — بيئة بدون SIEM

تضطر لجمع البيانات يدوياً من كل نظام على حدة، مما يُضيع الوقت ويزيد احتمال فوات الأدلة الحرجة.

🔍 Ted — بيئة مدعومة بـ SIEM

يرى كل التنبيهات والأجهزة في منصة واحدة، ويتتبع مسار الهجوم بسهولة وسرعة.

المصطلحات الأساسية في عالم SIEM

فهم هذه المصطلحات الثلاثة أمر حاسم لكل محلل أمني يعمل على منصات SIEM يومياً.

Normalization — التوحيد

عملية **تحويل السجلات** القادمة بصيغ مختلفة (JSON, XML, Plain Text) إلى صيغة موحدة وقابلة للمقارنة والتحليل الآلي.

Centralisation — المركزية

عملية **تجميع وتخزين السجلات (Logs)** من جميع الأنظمة في مستودع واحد مركزي، مما يُلغي الحاجة للتنقل بين أنظمة متفرقة.

Correlation — الربط

عملية **ربط الأحداث** القادمة من مصادر متعددة لتكوين صورة متكاملة عن الهجوم. بدون Correlation، كل حدث يبدو منفصلاً وغير ذي معنى.

أنواع مصادر البيانات في SIEM

يعتمد الـ SIEM على طبقات متعددة من مصادر البيانات. كل طبقة تكشف جانباً مختلفاً من الهجوم، والصورة الكاملة لا تكتمل إلا بتكاملها جميعاً.

Web-Based Logs

- خوادم Apache, Nginx, IIS
- Access Logs: كشف Brute Force, Web Shell, DDoS
- Error Logs: محاولات الاستغلال والأعطال

Network-Based Logs

- Firewalls, Routers, IDS/IPS
- رؤية تدفق البيانات بين الأجهزة
- كشف الهجمات الموزعة والاتصالات غير المصرح بها

Host-Based Logs

- أجهزة الموظفين (Workstations) والخوادم
- كشف البرمجيات الخبيثة وتغييرات الريجستري
- محاولات تصعيد الصلاحيات والملفات الجديدة

⚠️Critical alert: Always pay attention to time zone differences between the local system and the SIEM (usually UTC). Normalization is essential to standardize different log formats before analysis.

تحليل Windows Logs — التحقيق الميداني

مثال عملي — WINHOST05

- تنفيذ **update_config.js** عبر PowerShell مع EncodedCommand
- عملية **PPn423.exe** تتصل بـ IP خارجي 83.222.191.2 على Port 9999
- إنشاء مستخدم جديد عبر Security Logs — **محاولة Persistence**
- إنشاء خدمة "User Updates" — **محاولة تصعيد صلاحيات**

مصادر السجلات الرئيسية

WinEventLogs: — أحداث النظام والأمن والتطبيقات تسجيل الدخول، الحسابات، السياسات، تصعيد الصلاحيات.

Sysmon: — تنفيذ أداة متقدمة (تثبيت منفصل) العمليات، اتصالات الشبكة، حقن العمليات، تغييرات الملفات.

تحليل Linux Logs — كشف الاختراق

مثال عملي — سيناريو اختراق حقيقي

المستخدم المخترق	root تصعيد إلى ← jack-brown
حساب جديد	remote-ssh
IP المهاجم	10.10.101.12
محاولات فاشلة	7 مرات قبل النجاح
Port لـ Persistence	9999
ملف Cron مشبوه	pnr5433sw.sh (Perl reverse shell)

auth.log

يتابع محاولات تسجيل الدخول، استخدام **sudo**، وتصعيد الصلاحيات. يكشف هجمات **Brute-force** والوصول غير المصرح به.

syslog

يسجل أحداث النظام العامة، إعادة تشغيل الخدمات، و**Cron jobs** — يكشف آليات الـ Persistence مثل تشغيل shell عبر Cron.

تحليل Web Logs باستخدام Splunk

يُعدّ Splunk من أقوى أدوات تحليل سجلات الويب. فيما يلي أبرز سيناريوهات الهجوم وكيفية اكتشافها.

1

Brute Force على WordPress

البحث عن طلبات POST مكثفة على **wp-login.php/**

```
index=task6 method=POST
uri_path="/wp-login.php"
| bin _time span=5m
| stats count by clientip
_time
| where count > 25
```

النتائج: IP المهاجم: 10.10.243.134 | الأداة: WPScan v3.8.28 | الطلبات: 586

2

Web Shell Detection

البحث عن ملفات بامتدادات **.php, .asp, .jsp, .exe** مع POST/GET وعدد طلبات count > 2

مثال: ملف مشبوه باسم php.505 تم رفعه واستغلاله كـ Web Shell.

3

DDoS Attack

البحث عن استجابة **status=503** مع حجم هائل من الطلبات (أكثر من 100,000 خلال 10 دقائق).

المثال: 1.5 مليون طلب خلال 10 دقائق — دليل قاطع على هجوم DDoS.

استعلامات Splunk للتحقق والتأكيد

عرض كل التفاصيل

```
index=task6
| table _time
clientip
uri_path
status
useragent
count
```

عدد الطلبات لكل URI

```
index=task6
| stats count
 by uri_path
| sort -count
```

معرفة User-Agent

```
index=task6
uri_path="/wp-login.php"
clientip="10.10.243.134"
| stats values(useragent)
 as UserAgent
 count by clientip
 uri_path
```

أهم الدروس المستفادة — الخلاصة النهائية

بعد رحلة عملية شاملة عبر أدوات وتقنيات SIEM، إليك الركائز الأساسية التي يجب أن يتقنها كل محلل SOC.

🏗 تسهيل العمل

الـ SIEM يجمع البيانات، يربط الأحداث، ويسمح بالعودة للأحداث القديمة — الأداة الأهم للـ SOC Analyst.

🔗 تكامل المصادر

كل — Host + Network + Web + Cloud مصدر يكمل جزءاً من الصورة الجنائية الكاملة.

🎯 الدقة في التحليل

الـ Normalisation والـ Time Zones خطوتان حاسمتان لتوحيد البيانات وتجنب الأخطاء التحليلية.

التطبيق العملي بحسب المنصة

Web

تابع حجم الطلبات والأخطاء لكشف **Brute Force**، **Web Shells**، وهجمات **DDoS** عبر Splunk.

Linux

راقب **auth.log** لكشف Brute-force، و**Cron jobs** لكشف آليات الـ Persistence المخفية.

Windows

ركّز على الملفات المشبوهة، الاتصالات الخارجية غير المعتادة، وإنشاء الحسابات والخدمات الجديدة عبر WinEventLogs وSysmon.